Challenge 1 : Hash MD5 facile

On commence par créer un fichier texte :

```
┌──(carine㉿carine)-[~/Bureau]
└─$ nano md5.txt
```

Voici le contenu du fichier qui est le hash :

```
carine@carine: ~/Bureau
Session  Actions  Éditer  Vue  Aide
  GNU nano 8.6                                                    md5.txt *
827ccb0eea8a706c4c34a16891f84e7b
```

On lance l'attaque avec l'outil John the Ripper :

```
┌──(carine㉿carine)-[~/Bureau]
└─$ john --format=raw-md5 md5.txt
```

Résultat de l'attaque :

```
┌──(carine㉿carine)-[~/Bureau]
└─$ john --format=raw-md5 md5.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8×3])
Warning: no OpenMP support for this hash type, consider --fork=2
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
12345            (?)
1g 0:00:00:00 DONE 2/3 (2026-03-15 01:28) 25.00g/s 9600p/s 9600c/s 9600C/s 123456..larry
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

```
┌──(carine㉿carine)-[~/Bureau]
└─$ john --show --format=raw-md5 md5.txt
?:12345

1 password hash cracked, 0 left
```

On peut voir que le mot de passe qui se caché derrière ce hash est : 12345

Challenge 2 : attaque dictionnaire

On commence par créer un fichier texte :

```
┌──(carine㉿carine)-[~/Bureau]
└─$ nano hash2.txt
```

Voici le contenu du fichier qui est le hash :

```
carine@carine: ~/Bureau
Session  Actions  Éditer  Vue  Aide
  GNU nano 8.6                                                    hash2.txt *
e99a18c428cb38d5f260853678922e03
```

On lance l'attaque avec l'outil John the Ripper et la wordlist Rockyou :

```
┌──(carine㉿carine)-[~/Bureau]
└─$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash2.txt
```

Résultat de l'attaque :

```
┌──(carine㉿carine)-[~/Bureau]
└─$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash2.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8×3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
abc123           (?)
1g 0:00:00:00 DONE (2026-03-15 01:46) 33.33g/s 12800p/s 12800c/s 12800C/s 123456..michael1
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

```
┌──(carine㉿carine)-[~/Bureau]
└─$ john --show --format=raw-md5 hash2.txt
?:abc123

1 password hash cracked, 0 left
```

On peut voir que le mot de passe qui se caché derrière ce hash est : abc123

Qu’est-ce que le Hachage ?

Définition :

Le hachage (ou *hashing*) est l'un des piliers de la cybersécurité. C'est le processus qui permet de transformer n'importe quelle donnée (un mot de passe, un fichier, une phrase) en une suite de caractères unique et de longueur fixe.

Pourquoi l'utilise-t-on ?

A. Le stockage des mots de passe

Les sites web sérieux ne stockent jamais ton mot de passe "en clair". Ils stockent le hash.

- Quand tu te connectes, le site hache le mot de passe que tu tapes.
- Si le hash obtenu correspond au hash stocké en base de données, tu es connecté.
- Sécurité : Si le site est piraté, les hackers ne volent que des hashs inutilisables tels quels.

B. L'intégrité des fichiers

Quand tu télécharges un logiciel (comme une image ISO de Linux), le site fournit souvent un "checksum" (un hash). En calculant le hash du fichier téléchargé sur ton PC, tu peux vérifier qu'il n'a pas été corrompu ou modifié par un pirate.

C. La Blockchain

Le Bitcoin et les autres crypto-monnaies utilisent le hachage pour lier les blocs entre eux. Chaque bloc contient le hash du bloc précédent, créant une chaîne immuable.

Qu'est-ce que le hash MD5 ?

MD5 signifie Message Digest 5. C'est une fonction de hachage cryptographique qui prend une entrée (un mot, une phrase, ou un fichier entier) et produit une empreinte de 128 bits, généralement affichée sous la forme d'une suite de 32 caractères hexadécimaux (chiffres de 0 à 9 et lettres de a à f).

Les caractéristiques du MD5 :

- Rapidité : Il a été conçu pour être extrêmement rapide à calculer.
- Taille fixe : Que tu haches le mot "Salut" ou un film de 4 Go, le résultat fera toujours exactement 32 caractères.
- Sens unique : Tu ne peux pas retrouver le mot de passe "apple" simplement en faisant un calcul inverse sur son hash `e99a18c4....`

Challenge 1 : L'attaque par "Force Brute" (Hash MD5)

Le But :

L'objectif était d'apprendre à retrouver un mot de passe caché derrière une empreinte numérique (le Hash), en utilisant la méthode de la force brute. C'est la base fondamentale du "password cracking" en cybersécurité.

Le Scénario:

- Le Secret : On possède un fichier (md5.txt) contenant une suite de caractères illisibles : 5f4dcc3b5aa765d61d8327deb882cf99.

- L'Algorithme : On sait que ce secret a été créé avec MD5, un ancien format très rapide mais aujourd'hui considéré comme vulnérable.

- L'Outil : On utilise John the Ripper, un logiciel professionnel capable de tester des milliers de combinaisons par seconde.

Qu'est-ce que l'outil John the Ripper ?

John the Ripper (souvent abrégé JTR) est l'un des outils de test de pénétration et de craquage de mots de passe les plus célèbres au monde. C'est un outil "open-source" (libre) utilisé par les administrateurs système pour vérifier la sécurité de leurs serveurs et par les experts en cybersécurité pour tester la robustesse des accès.

Qu'est-ce qu'une attaque Brute Force ?

Une attaque par force brute (*Brute Force Attack*) est une technique utilisée en cybersécurité pour trouver un mot de passe ou une clé de chiffrement en testant toutes les combinaisons possibles jusqu'à trouver la bonne.

Le Principe:

L'attaquant utilise un programme automatisé qui va essayer énormément de mots de passe très rapidement.

Type d'attaques :

Type d'attaque	Principe	Quand l'utiliser ?
Brute Force Classique	Teste mathématiquement toutes les combinaisons possibles (aaa, aab, aac...).	Quand on n'a aucune info sur le mot de passe (c'est l'attaque la plus longue).
Attaque par Dictionnaire	Teste uniquement des listes de mots réels (ex: rockyou.txt).	Quand l'utilisateur a probablement choisi un mot commun, un prénom ou un fruit.
Brute Force "Masquée"	On donne un modèle à l'ordinateur (ex: "commence par 'S' et finit par '2024'").	Quand on sait que la cible suit une logique (ex: Soline2024).
Attaque Hybride	Mélange un dictionnaire et des caractères (ex: prend apple et teste apple1, apple2...).	Quand l'utilisateur ajoute un chiffre ou un symbole à la fin d'un mot simple.
Credential Stuffing	Teste des couples (email/mot de passe) déjà volés sur d'autres sites.	Quand on parie sur le fait que l'utilisateur réutilise le même mot de passe partout.
Brute Force Inverse	Teste un mot de passe très commun (ex: 123456) sur des milliers de comptes différents.	Pour éviter de se faire bloquer un compte après trop d'essais infructueux.

Challenge 2 : L'Attaque par Dictionnaire (Wordlist)

Le But:

L'objectif était de démontrer qu'un mot de passe, même s'il n'est pas "évident" (comme 12345), peut être trouvé instantanément s'il appartient au langage courant ou à une liste de mots de passe déjà fuités sur Internet.

Le Scénario:

- Le Secret : On possède un hash MD5 plus complexe : e99a18c428cb38d5f260853678922e03.

- L'Algorithme : Toujours du MD5, mais cette fois-ci, on n'utilise pas la force brute aveugle.

- L'Outil & La Ressource : On utilise John the Ripper couplé à un dictionnaire célèbre appelé rockyou.txt. Ce fichier contient des millions de vrais mots de passe issus de piratages historiques.

Qu'est-ce qu'une wordlist ?

Une wordlist (ou liste de mots) est tout simplement un fichier texte contenant une immense liste de mots, de noms, de chiffres ou d'anciens mots de passe, rangés à raison d'un par ligne. En cybersécurité, c'est le "carburant" indispensable pour les attaques par dictionnaire.

À quoi ça sert ?

Plutôt que de laisser un logiciel comme John the Ripper tester des combinaisons aléatoires et mathématiques ($aaaaa$, $aaaab$...), on lui donne une wordlist. L'outil va alors tester uniquement les mots présents dans ce fichier.

L'idée est simple : Puisque les humains sont prévisibles et choisissent souvent des mots qui existent, pourquoi perdre du temps à tester des combinaisons qui ne veulent rien dire ?

Qu'est-ce que rockyou.txt ?

Dans le milieu de la cybersécurité, rockyou.txt est bien plus qu'un simple fichier texte : c'est une véritable pièce d'anthologie. C'est la "wordlist" (liste de mots) la plus célèbre et la plus utilisée au monde pour tester la solidité des mots de passe.

Où la trouver ?

Sur Kali Linux, elle est pré-installée (mais compressée pour gagner de la place) dans le dossier des listes de mots.

> Le savais-tu ? Pour l'utiliser la première fois sur Kali, il faut souvent le décompresser avec cette commande : sudo gunzip /usr/share/wordlists/rockyou.txt.gz

Tableau récapitulatif des formats de hash les plus ciblés :

Format	Type / Utilisation	Sécurité	Pourquoi les hackers l'aiment ?
MD5	Vieux sites, intégrité de fichiers	Très Faible	Ultra rapide à casser (milliards de tests/sec).
SHA-1	Anciens certificats SSL, Git	Faible	Devenu vulnérable aux collisions et très rapide.
NTLM	Réseaux Windows (Active Directory)	Moyenne	Utilisé pour le "Pass-the-Hash" dans les entreprises.
SHA-256	Blockchain (Bitcoin), HTTPS	Haute	Standard actuel, difficile à casser si le MDP est long.
SHA-512	Système Linux (/etc/shadow)	Très Haute	Conçu pour être lent et gourmand en calcul (Challenge 3).
Bcrypt	Applications Web modernes (PHP, JS)	Excellente	Intègre un "coût" qui ralentit volontairement l'attaque.

Commande pour voir les options de John the Ripper :

```
┌──(carine㉿carine)-[~/Bureau]
└─$ john --help
```

Commande pour voir la version :

```
┌──(carine㉿carine)-[~/Bureau]
└─$ john
John the Ripper 1.9.0-jumbo-1+bleeding-aec1328d6c 2021-11-02 10:45:52 +0100 OMP [linux-gnu 64-bit x86_64 AVX2 AC]
Copyright (c) 1996-2021 by Solar Designer and others
Homepage: https://www.openwall.com/john/

Usage: john [OPTIONS] [PASSWORD-FILES]

Use --help to list all available options.
```